

# ランサムウェアリークサイト観測に基づく 二重脅迫の交渉戦略と攻撃グループ間で共通する被害者の分析

余郷 辰樹<sup>†</sup> インミンパパ<sup>††</sup> 四方 順司<sup>†††,†</sup> 吉岡 克成<sup>†††,††</sup>

<sup>†</sup> 横浜国立大学大学院環境情報学府

<sup>††</sup> 横浜国立大学先端科学高等研究院

<sup>†††</sup> 横浜国立大学大学院環境情報研究院

E-mail: <sup>†</sup>yogo-tatsuki-xm@ynu.jp, <sup>††</sup>{yinminn-papa-jp,shikata-junji-rb,yoshioka}@ynu.ac.jp

**あらまし** 近年のランサムウェア攻撃では、窃取した情報を公開すると脅す二重脅迫が一般化しており、攻撃者が運営するリークサイトは被害者に圧力を与える重要な手段となっている。本研究では、5つのランサムウェアグループのリークサイトを継続的に観測し、被害者名、掲載日時などの掲載情報の種類や掲載状態の推移、リークサイト上で攻撃者が設定する、窃取情報を公開するまでの身代金支払い期限（以下、公開期限）の運用、および複数グループに共通して掲載される被害者を分析した。その結果、掲載情報の種類や掲載状態の推移にはグループごとの差異が見られた。また、公開期限の運用にも大きな差があり、Play では比較的厳格に期限が運用される一方、Medusa では期限前公開、Qilin では期限延長が多く、公開期限がグループによっては必ずしも実際の締切として機能しないことが示された。さらに、Play と Qilin の共通被害者では9件中8件で Qilin が後に掲載しており、複数グループ間で被害者情報の再利用や攻撃対象の重複可能性を検討するための手がかりが得られた。

## Analysis of Double-Extortion Negotiation Strategies and Shared Victims Across Ransomware Groups Based on Ransomware Leak Site Observations

Tatsuki YOGO<sup>†</sup>, Yin Minn Pa Pa<sup>††</sup>, Junji SHIKATA<sup>†††,†</sup>, and Katsunari YOSHIOKA<sup>†††,††</sup>

<sup>†</sup> Graduate School of Environment and Information Sciences, Yokohama National University

<sup>††</sup> Institute of Advanced Sciences, Yokohama National University

<sup>†††</sup> Faculty of Environment and Information Sciences, Yokohama National University

E-mail: <sup>†</sup>yogo-tatsuki-xm@ynu.jp, <sup>††</sup>{yinminn-papa-jp,shikata-junji-rb,yoshioka}@ynu.ac.jp

**Abstract** In recent ransomware attacks, double extortion, in which attackers threaten to publish stolen information, has become common, and leak sites operated by attackers have become an important means of pressuring victims. In this study, we continuously observed the leak sites of five ransomware groups and analyzed the types of posted information, transitions in listing status, the operation of ransom payment deadlines before the publication of stolen data, and victims commonly listed across multiple groups. The results showed differences among groups in the types of posted information and transitions in listing status. We also found large differences in the operation of these deadlines: Play operated them relatively strictly, whereas Medusa frequently published data before the deadline and Qilin frequently extended deadlines. These findings indicate that, depending on the group, the deadlines do not necessarily function as actual deadlines. Furthermore, among the nine victims common to Play and Qilin, Qilin listed eight of them later, providing clues for examining possible reuse of victim information and possible overlap in attack targets across multiple groups.

### 1. はじめに

近年、ランサムウェア攻撃では、データの暗号化に加えて

窃取情報の公開を脅迫材料とする二重脅迫が一般化している。このような攻撃では、攻撃者グループが運営するリークサイトが、被害者に心理的・社会的圧力を与える手段として用いら

れている。リークサイトには、被害組織名、漏洩データの一部、窃取情報を公開するまでの身代金支払い期限（以下、公開期限）などが掲載されることがあり、これらの情報は、情報窃取の事実を示すことで攻撃の信憑性を高める、公開期限を提示して被害者に意思決定を迫る、漏洩データの一部や閲覧数を示して社会的圧力を強める、といった脅迫戦略を反映している可能性がある [1]～[3]。

既存研究では、ランサムウェア自体の解析、特定グループの活動実態、支払い経済などが分析されてきた [4], [5]。また、LockBit3.0 のような特定のランサムウェアグループについて、リークサイト上の被害者情報や身代金額、支払い期限の時間的変化を継続的に観測し、攻撃者と被害者の行動を推定する研究も行われている [2], [3]。これらの研究により、単一グループのリークサイト上では、掲載状態、公開期限、金額タグ、チャット履歴などの変化から、攻撃者と被害者の交渉過程を推定できる可能性が示されている。

一方で、複数のランサムウェアグループを横断し、掲載情報、掲載状態、公開期限の運用、共通被害者の出現傾向を比較した研究は限定的である。リークサイトの運用はグループごとに異なる可能性があり、単一グループの分析だけでは、観測された特徴が特定グループ固有のものか、リークサイト全体に共通する傾向かを判断しにくい。また、同一または関連する被害者が複数グループに掲載される事例は、攻撃対象の重複や被害者情報の再利用可能性を検討する手がかりとなるが、その実態は十分に整理されていない。

そこで本研究では、リークサイト上で継続的な掲載活動が確認でき、公開期限や掲載状態の比較が可能であった LockBit3.0, Play, DragonForce, Medusa, Qilin を対象とし、掲載情報の内容、掲載状態の時間的変化、公開期限の運用、および複数グループに共通して掲載される被害者の関係性を分析する。本研究のリサーチクエスションは以下の3点である。

RQ1：リークサイト上の被害者掲載情報および掲載状態の変化には、グループごとにどのような特徴があるか。

RQ2：リークサイト上の公開期限は、実際の公開・削除・延長とどのように対応しているか。

RQ3：複数のランサムウェアグループに共通して掲載される被害者から、グループ間の類似性や関係性をどの程度推測できるか。

これらの研究課題に答えるため、本研究では、リークサイト上の掲載情報を継続的に自動収集した。観測期間はグループごとに異なり、LockBit3.0 は 2023 年 6 月から、DragonForce および Play は 2025 年 6 月から、Medusa は 2025 年 7 月から、Qilin は 2025 年 12 月から観測を開始し、いずれも 2026 年 3 月中旬までのデータを用いた。観測により、LockBit3.0 で 1,889 件、Play で 1,025 件、DragonForce で 405 件、Medusa で 272 件、Qilin で 1,309 件の被害者情報を収集し、合計 4,900 件の被害者情報を得た。収集したデータを被害者単位で時系列に整理し、RQ1 に対しては掲載情報の種類と掲載状態の遷移を、RQ2 に対しては公開期限の長さ、延長、期限前公開、期限後の掲載状態を、RQ3 に対しては複数グループ間で共通して掲載された

被害者の件数、割合、掲載順序を分析した。

分析の結果、対象とした 5 つのランサムウェアグループでは、リークサイトに掲載される情報の種類や掲載状態の推移に差異が見られた。また、リークサイト上で表示される公開期限の運用にはグループごとの差が大きく、Play では公開期限の延長割合が 4.4%、期限前公開が 1.2% であった一方、Medusa では期限前公開が 77.4%、Qilin では延長割合が 88.2% であった。このことから、公開期限はグループによっては比較的厳格に運用される一方で、必ずしも実際の締切として機能せず、脅迫を演出する要素として利用されている可能性が示された。さらに、共通被害者の分析では、LockBit3.0 と Play、LockBit3.0 と Qilin でそれぞれ 10 件、Play と Qilin で 9 件、Medusa と Qilin で 5 件の重複が確認され、割合としては全体に対して限定的である一方、Play と Qilin の共通被害者 9 件中 8 件、Medusa と Qilin の共通被害者 5 件中 4 件では Qilin が後に掲載しており、一部のグループ間では掲載順序に偏りが見られた。これらの結果は、掲載情報や公開期限の運用がグループごとに異なり、被害者の重複も限定的であることから、単一グループの観測だけではランサムウェア攻撃の全体像や運用実態を十分に把握することが難しいことを示している。したがって、複数グループを継続的に観測し、横断的に比較する必要がある。

本研究の貢献は以下の 3 点である。第一に、複数のランサムウェアグループのリークサイトを継続的に観測し、掲載情報や掲載状態の変化を時系列的に比較した。第二に、公開期限の延長、期限前公開、期限後の掲載状態を比較し、公開期限が実際の締切や交渉状況の手がかりとしてどの程度解釈可能かを検討するための基礎的知見を示した。第三に、共通被害者の件数、割合、掲載順序を分析し、複数グループを横断して観測・比較する必要性を示した。

## 2. 関連研究

ランサムウェアに関する既存研究では、マルウェア本体の解析、感染手法、暗号化処理、検知・防御手法などが広く扱われてきた。Oz らは、ランサムウェアの進化、分類、防御手法を体系的に整理しており、ランサムウェアが PC、モバイル端末、IoT/CPS など多様な環境に拡大していることを示している [4]。また、Oosthoek らは、Bitcoin 取引に基づいてランサムウェアの支払い経済を分析し、コモディティ型ランサムウェアと Ransomware as a Service (RaaS) という異なる市場構造が存在することを示している [5]。警察庁の報告でも、ランサムウェア攻撃は国内外で継続的に重要なサイバー脅威として扱われている [6]。これらの研究や報告は、ランサムウェア攻撃の技術的特徴や経済的背景、社会的影響を理解する上で有用であるが、リークサイト上の被害者情報、公開期限、掲載状態の運用までは十分に扱っていない。

近年のランサムウェア攻撃では、窃取情報の公開を脅迫材料とする二重脅迫や、RaaS による分業化が進んでいる。Meurs らは、二重脅迫型ランサムウェアにおける攻撃者の欺瞞、収益性、信頼性を分析し、攻撃者が被害者に支払いを促すために公開や削除に関する信頼性をどのように維持するかを議論して

表 1: 対象グループと収集データの概要

| グループ        | 観測開始時期      | 分析終了       | 観測状況 | 掲載被害者数 |
|-------------|-------------|------------|------|--------|
| LockBit3.0  | 2023 年 6 月  | 2026 年 3 月 | 継続中  | 1,889  |
| Play        | 2025 年 6 月  | 2026 年 3 月 | 継続中  | 1,025  |
| DragonForce | 2025 年 6 月  | 2026 年 3 月 | 継続中  | 405    |
| Medusa      | 2025 年 7 月  | 2026 年 3 月 | 継続中  | 272    |
| Qilin       | 2025 年 12 月 | 2026 年 3 月 | 継続中  | 1,309  |
| 合計          | -           | -          | -    | 4,900  |

いる [1]. このような研究は、リークサイト上の公開期限や掲載状態を、単なる表示情報ではなく、交渉や脅迫に関わる要素として捉える上で重要である。

ランサムウェアリークサイトに着目した研究として、関根らは LockBit3.0 のリークサイトを 166 日間観測し、被害者情報の掲載状態、公開期限、金額タグ、チャット履歴の時間的変化を分析している [2]. また、Y. M. Pa Pa らは LockBit3.0 を対象に 532 日間の長期観測を行い、恐喝プロセスを非公開段階での交渉、公開期限による公開前交渉、公開後の収益化という三段階のライフサイクルとして整理している [3]. これらの研究は、リークサイト上の掲載状態や公開期限の変化から、攻撃者と被害者の交渉状況を推定できる可能性を示している。

しかし、既存研究の多くは特定のランサムウェアグループ、特に LockBit3.0 を中心とした分析にとどまっており、複数のランサムウェアグループ間で掲載情報、掲載状態、公開期限の運用がどのように異なるのかは十分に明らかにされていない。また、同一または関連する被害者が複数グループのリークサイトに掲載される事例についても、横断的な分析は限定的である。そこで本研究では、LockBit3.0, Play, DragonForce, Medusa, Qilin の 5 グループを対象に、掲載情報の種類、掲載状態の推移、公開期限の運用、および複数グループに共通して掲載される被害者を分析する。

### 3. 手 法

本研究では、複数のランサムウェアグループが運営するリークサイトを継続的に観測し、被害者情報の掲載内容、掲載状態の時間的変化、公開期限の運用、ならびに複数グループに共通して掲載される被害者を分析した。本節では、対象グループ、データ収集方法、前処理、および各研究課題に対応する分析方法について述べる。

#### 3.1 対象グループ

本研究では、LockBit3.0, Play, DragonForce, Medusa, Qilin の 5 グループを分析対象とした。これらのグループは、観測期間中にリークサイト上で継続的な掲載活動が確認でき、被害者情報、公開期限、掲載状態の変化を比較可能な形式で取得できたことから対象とした。

対象グループごとの観測期間と収集件数を表 1 に示す。観測開始時期はグループごとに異なる。いずれのグループについても、観測自体は継続しているが、2026 年 3 月中旬までに収集したデータを本研究の分析対象とした。

#### 3.2 データ収集

各リークサイトに対して定期的にアクセスし、掲載されている被害者情報を自動的に収集した。収集間隔は原則として 6 時間ごととした。これは、1 日単位の観測では公開期限の変更、期限前公開、掲載削除などの短時間の変化を十分に追跡できない可能性があるためである。また、LockBit3.0 を対象とした先行研究でも、観測開始直後を除き 6 時間ごとの収集が用いられている [2]. 各収集時点で確認できた被害者情報を JSON 形式で保存し、被害者情報が初めて観測された時刻、掲載内容が更新された時刻、公開期限が変更された時刻、および掲載が確認できなくなった時刻を時系列的に追跡できるようにした。

収集対象には、各リークサイトの HTML ファイルから得られる被害者情報全てを含めた。ただし、リークサイトの構造や掲載項目はグループごとに異なるため、取得可能な項目はグループによって異なる。そのため、本研究では、各グループ固有の項目を保持しつつ、グループ間比較に必要な共通項目を抽出して分析に用いた。データ収集には Selenium WebDriver [7] および BeautifulSoup [8] を用いた。また、Tor 上で公開されているリークサイトへのアクセスには、Tor プロキシを用いた [11].

#### 3.3 データ前処理

収集したデータは、グループごとにリークサイトの HTML 構造や CSS クラス名、JSON 形式で保存した際のキー名が異なるため、分析前に共通の形式へ変換した。具体的には、被害組織名、ドメイン、観測時刻、サイト上の掲載日時、説明文、所在地、窃取データの概要、データサイズ、サンプルデータの有無、ダウンロードリンクの有無、閲覧数、要求金額、公開期限表示の有無、被害組織の ZoomInfo へのリンク [14] の中から掲載されている情報を項目として整理した。これにより、異なる構造を持つリークサイトから取得したデータを、グループ間で比較可能な形式に統一した。

掲載状態の分析に用いるため、各収集時点における被害者情報の掲載の有無、公開期限の有無、および過去の掲載履歴を整理した。また、過去に確認された被害者情報がある収集時点で確認できなくなった場合には、当該時点を掲載が確認できなくなった時点として記録した。ただし、掲載が確認できなくなった理由は、本研究の収集データのみから厳密に区別できない。集計結果の可視化には Plotly [9] を用いた。

#### 3.4 掲載情報・掲載状態の分析

RQ1 に答えるため、各グループのリークサイトに掲載される情報を比較した。本研究では、分析者が特定の項目を事前に選定したのではなく、各リークサイトに掲載されていた被害者情報を可能な限り抽出し、そのうちグループ間で比較可能な項目を整理した。

また、各観測時点において確認された被害者情報を、公開期限の有無と再掲載の有無に基づいて分類し、状態ごとの件数をグループ別に計測した。本研究では、公開期限が表示されている被害者を公開前状態、公開期限が表示されていない被害者を公開状態として扱った。ここでいう公開期限には、日時として表示される期限と、公開までの残り時間を示すカウントダウン表示の双方を含む。同一被害者の対応付けには、公式

ドメインが取得できる場合は公式ドメインを用い、公式ドメインが取得できない場合は被害組織名を用いた。また、一度リークサイト上で確認できなくなった被害者が再び確認された場合でも、短時間の欠損は収集失敗やサイト改修の影響である可能性があるため、前回の掲載確認時刻から 150 時間以上経過した後に再び確認された場合を再掲載と定義した。150 時間は、一時的な収集失敗や数日程度のサイト停止を再掲載として誤判定することを避けるための閾値である。

各収集時点、すなわち原則 6 時間ごとの観測時点において、これらの状態別に被害者数を集計し、グループごとの掲載状態の推移を比較した。

### 3.5 公開期限の分析

RQ2 に答えるため、リークサイト上に表示される公開期限が、実際の掲載状態の変化とどのように対応しているかを分析した。具体的には、各被害者について、公開期限の長さ、期限延長の有無や回数、公開期限より前にデータが公開されたかなどを整理した。

本研究では、公開期限の運用を評価するため、主に以下の指標を用いた。

- ・ 期限延長割合：公開期限が観測された被害者を分母とし、公開期限が一度以上後ろ倒しに変更された被害者の割合
- ・ 期限前公開割合：公開期限が観測された被害者を分母とし、設定された公開期限より前に公開状態へ移行した被害者の割合
- ・ 期限前削除割合：公開期限が観測された被害者を分母とし、公開期限より前に被害者情報がリークサイト上で確認できなくなった被害者の割合
- ・ 期限長：被害者情報の初回観測時点から、初回到観測された公開期限までの期間。ただし、本研究では観測時点を基準としており、観測開始時点で期限付きで掲載されていた被害者については、真の掲載開始時刻を観測できていないため、期限長が実際より短く推定される可能性がある。

これらの指標をグループごとに比較することで、公開期限が実際の締切に近い形で運用されているのか、あるいは表示上の期限として柔軟に変更されているのかを検討した。

### 3.6 共通被害者の分析

RQ3 に答えるため、複数グループのリークサイトに掲載された被害者のうち、同一または関連する組織と推定される組合せを抽出した。本研究では、まず各 JSON から被害組織名、ドメイン、所在地、説明文などを抽出した。被害組織名は、name, title, victim などのキーから抽出した。公式ドメインは、domain, url, website などのキーから抽出した。一方、説明文や注記に含まれるドメインは、ファイル共有サービスや外部ホスティングサービスの URL である可能性があるため、公式ドメインとしては扱わず、参考情報としてのみ保持した。また、.onion ドメイン、短縮 URL、ファイル共有サービス、ソースコード共有サービスなどのドメインは、企業公式ドメイン

の候補から除外した。企業名の正規化では、小文字化、前後空白の削除、法人格表記の除去、記号の除去、連続空白の圧縮を行った。法人格表記としては、inc, llc, ltd など除去した。また、name フィールドに URL やドメインが含まれる場合には、企業名としてではなくドメイン情報として扱った。

同一グループ内では、まず公式ドメインを用いて同一被害者を統合し、公式ドメインが取得できない場合には正規化後の企業名を用いて統合した。それでも識別できない場合には、参考情報として抽出されたドメインを用いた。この統合により、同一グループ内で同一被害者が複数の観測結果に出現する場合でも、1 件の被害者として扱った。

次に、グループ間の被害者比較を行った。公式ドメインが一致する組合せは、同一組織として same と判定した。また、正規化後の企業名が完全一致する組合せも same とした。これらで一致しない場合には、RapidFuzz の token set ratio を用いて企業名およびドメイン由来のラベル間の文字列類似度を計算し [10]、類似度が 65 以上の候補のうち上位 20 件を LLM 判定の対象とした。企業名には略称、表記ゆれ、グループ会社名の違いなどが含まれるため、ドメイン一致や文字列類似度のみでは、同一組織か関連組織かを判定できない場合がある。また、複数グループ間の被害者候補を網羅的に比較すると多数の組合せが生じるため、すべてを手手で判定することは現実的ではない。そこで、文字列類似度により候補を絞り込んだ上で、被害組織名、公式ドメイン、所在地、説明文を総合的に考慮した一次判定を行うために LLM を用いた。LLM には GPT-4.1-mini を用い、被害組織名、公式ドメイン、所在地、説明文を入力として、same, related, different の 3 分類を行わせた。same は同一企業と判断される場合、related は同一企業グループ、関連会社、同一ブランドの別法人など関連性が高い場合、different は別組織と判断される場合と定義した。LLM によって same または related と判定された組合せを共通被害者の候補とし、出力された CSV を著者が確認した。その際、被害組織名、公式ドメイン、所在地、説明文、LLM の判定理由を確認し、same または related とされた組合せが実際に同一または関連する組織と見なせるかを確認した。最終的に、same または related と確認された組合せを、共通被害者として分析対象とした。

さらに、各共通被害者について、各グループで最初に観測された JSON ファイルを特定し、ファイル名から推定した観測時刻に基づいて掲載順序を比較した。各 JSON ファイル名には収集時刻を ISO 8601 形式で付与しており、この時刻を観測時刻として用いた。例えば、2026-03-01T06-00-00.json のようなファイル名から日時部分を抽出し、各被害者が最初に出現したファイルの時刻を初回観測時刻とした。ただし、同一または関連する被害者が複数グループのリークサイトに掲載されたとしても、その事実だけから、グループ間で被害者情報が共有された、あるいは攻撃基盤や IAB が移動したと断定することはできない。同一組織が独立に複数回攻撃された可能性や、同一企業グループ内の別法人が掲載された可能性もあるためである。そのため、共通被害者はグループ間の直接的な関係を示す証拠ではなく、被害者情報や攻撃対象の重複可能性を

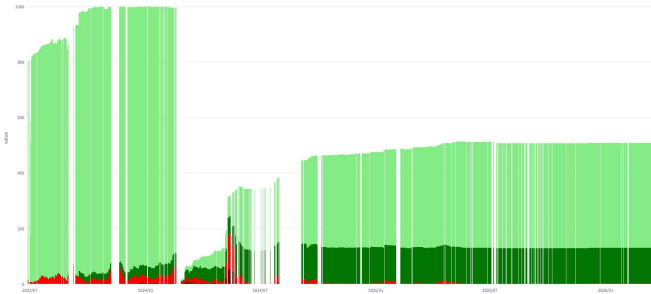


図 1: LockBit3.0 における掲載状態別被害者数の時系列変化。緑は公開状態，赤は公開期限が表示されている期限付き掲載状態を示す。濃い色は，一度確認できなくなった後に再び掲載された再掲載状態を示す。横軸は観測時刻，縦軸は各観測時点で確認された被害者数である。

検討するための手がかりとして扱う。

## 4. 結果

本節では，収集したリークサイトデータを用いて，3つのリサーチクエストに対応する分析結果を示す。まず，RQ1に対応して，各グループのリークサイトに掲載される情報項目と，各観測時点における掲載状態別の被害者数を比較する。次に，RQ2に対応して，公開期限が，実際の掲載状態の変化とどのように対応しているかを分析する。最後に，RQ3に対応して，複数グループに共通して掲載された被害者の件数，割合，掲載順序を分析する。

### 4.1 掲載情報・掲載状態の比較

RQ1に答えるため，まず各グループのリークサイトに掲載される情報項目を比較した。表2に，各グループで確認された主な掲載情報項目を示す。

対象とした5グループはいずれも被害組織に関する情報を掲載していたが，掲載される項目の種類にはグループごとに差異が見られた。被害者名，公開期限，掲載日時，企業の詳細など全てのグループに掲載される項目もあれば，要求金額，漏洩情報のサイズ，攻撃者のコメントなど一部のグループでしか掲載されていない項目も見られた。また，Qilinでは一部の被害者についてZoomInfoへのリンクが確認され，他グループとは異なる外部企業情報の提示が見られた。このように，リークサイト上で提示される情報項目はグループごとに異なっていた。

次に，各観測時点における掲載状態別の被害者数をグループごとに集計した。図1～3に，掲載状態の推移に特徴が見られた代表例として，LockBit3.0，DragonForce，Qilinの掲載状態別件数の推移を示す。

この図では，各観測時点において，過去に削除された被害者の再掲載でないか，公開期限が表示されているかに基づいて掲載状態を分類している。緑は公開状態，赤は公開期限が表示されている期限付き掲載状態，それぞれの濃い色は再掲載状態を示す。各値は，各観測時点でリークサイト上に確認できた被害者を状態ごとに集計したものである。

LockBit3.0では，2024年2月に国際的な法執行活動Operation

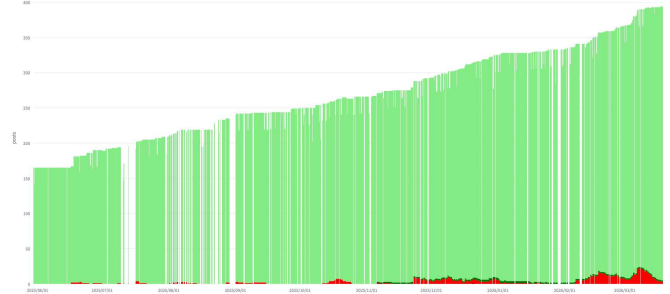


図 2: DragonForce における掲載状態別被害者数の時系列変化。色の意味は図1と同様である。

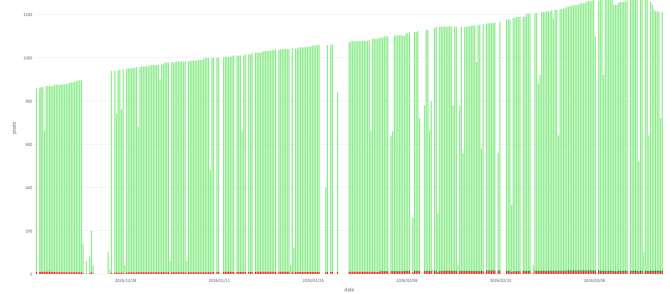


図 3: Qilin における掲載状態別被害者数の時系列変化。色の意味は図1と同様である。

Cronosにより，リークサイトを含む関連インフラが妨害された[12],[13]。その影響により，一時的に掲載数が大きく減少し，その後，再び掲載される被害者が増加した。このことから，LockBit3.0ではサイト運用上の変化や外部要因によって，掲載状態が大きく変動した可能性がある。

DragonForceでは，掲載数は全体として増加傾向にあったが，一部の期間で公開期限付きの被害者がまとまって増加する傾向が見られた。このことから，DragonForceでは全体として掲載数を継続的に増加させつつ，一部の期間に期限付き掲載を集中的に行う運用が存在した可能性がある。

Qilinでは，各観測時点で公開期限が確認される被害者数が一定規模で維持されていた。これは，新規の期限付き掲載や期限延長により，公開期限付きの被害者を一定以上に保とうとする傾向を示している可能性がある。

一方，図には示していないが，Playでは全体の掲載数は多いものの，掲載状態の急激な変化は見られず，比較的安定して推移していた。また，各観測時点で公開期限が確認される被害者数は相対的に少なかった。Medusaでは安定した被害者数の増加や再掲載を含む変動が見られ，LockBit3.0と類似した掲載状態の推移を示していた。

以上より，RQ1に対して，リークサイト上の掲載情報および掲載状態の推移には，グループごとに差異があることが分かった。掲載情報の観点では，それぞれのグループで異なる項目構成が見られた。掲載状態の観点では，LockBit3.0やMedusaのように再掲載を含む変動が見られるグループ，DragonForceのように一部期間で期限付き掲載がまとまって増加するグルー



表 2: 各グループのリークサイトに掲載される情報項目

| グループ名       | 被害者名 | ドメイン | 要求金額 | 公開期限 | 掲載日時 | 閲覧数 | 企業の詳細 | ZoomInfo | 漏洩情報のサイズ | 漏洩情報の一部 | ダウンロードリンク | 攻撃者のコメント |
|-------------|------|------|------|------|------|-----|-------|----------|----------|---------|-----------|----------|
| LockBit3.0  | ✓    | ✓    | ✓    | ✓    | ✓    | ✓   | ✓     |          |          | ✓       | ✓         |          |
| Play        | ✓    | ✓    |      | ✓    | ✓    | ✓   | ✓     |          |          | ✓       | ✓         | ✓        |
| DragonForce | ✓    | ✓    |      | ✓    | ✓    |     | ✓     |          | ✓        |         | ✓         |          |
| Medusa      | ✓    |      | ✓    | ✓    | ✓    | ✓   | ✓     |          |          | ✓       | ✓         |          |
| Qilin       | ✓    | ✓    |      | ✓    | ✓    |     | ✓     | ✓        | ✓        |         |           | ✓        |

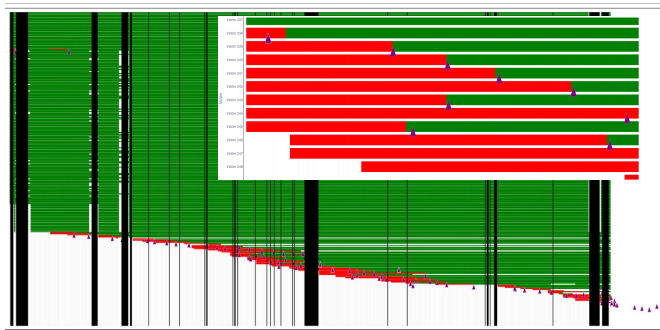


図 4: Medusa における被害者ごとの掲載状態と公開期限の時系列変化。全体図に加えて、公開期限周辺の一部を拡大して示す。

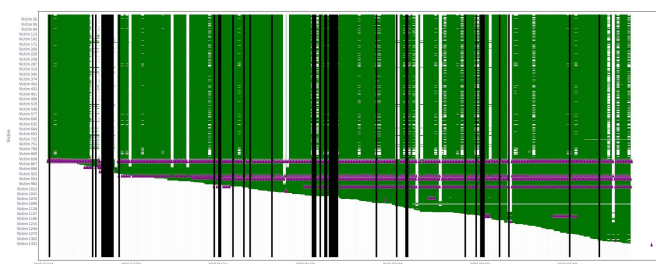


図 5: Qilin における被害者ごとの掲載状態と公開期限の時系列変化

プ、Qilin のように期限付き掲載を一定規模で維持するグループ、Play のように比較的安定して推移するグループが存在した。

#### 4.2 公開期限の運用

RQ2 に答えるため、リークサイト上に表示される公開期限が、実際の掲載状態の変化とどのように対応しているかを分析した。公開期限運用の代表例として、Medusa および Qilin における被害者ごとの掲載状態と公開期限の時系列変化を図 4 および図 5 に示す。これらの図では、各被害者を行方向に並べ、観測時点ごとの掲載状態を色で示している。図中の緑は公開中の状態、赤は公開期限が確認された状態、黒は観測不能期間を示す。紫の点は各観測時点で確認された公開期限を示しており、公開期限が更新された場合には、更新前の期限も含めて全てプロットしている。図 4 では、Medusa の全体図に加えて、公開期限周辺の一部を拡大して示す。

図 4 の拡大部より、Medusa では公開期限より前に公開状態へ移行する事例が確認された。また、図 5 では紫の点が広範囲に分布しており、Qilin では公開期限が繰り返し更新される事例が確認できる。

また、表 3 に、グループごとの公開期限運用に関する指標を

表 3: グループごとの公開期限運用

| グループ        | 期限延長割合 | 平均延長回数 | 期限長（中央値） | 期限前公開割合 | 期限前削除割合 |
|-------------|--------|--------|----------|---------|---------|
| LockBit3.0  | 25.1%  | 3.08   | 298.3h   | 10.9%   | 13.0%   |
| Play        | 4.4%   | 1.73   | 75.0h    | 1.2%    | 6.0%    |
| DragonForce | 14.1%  | 1.39   | 136.4h   | 0.0%    | 7.8%    |
| Medusa      | 19.2%  | 6.83   | 376.5h   | 77.4%   | 11.5%   |
| Qilin       | 88.2%  | 25.7   | 328.0h   | 17.6%   | 41.2%   |

表 4: グループ間の共通被害者数と掲載順序

| グループ組合せ                | 共通被害者数 | 後続掲載が多いグループ | 後続件数 |
|------------------------|--------|-------------|------|
| LockBit3.0–Play        | 10     | Play        | 10   |
| LockBit3.0–Qilin       | 10     | Qilin       | 10   |
| Play–Qilin             | 9      | Qilin       | 8    |
| Medusa–Qilin           | 5      | Qilin       | 4    |
| DragonForce–Play       | 3      | DragonForce | 3    |
| DragonForce–Qilin      | 2      | DragonForce | 2    |
| LockBit3.0–Medusa      | 2      | Medusa      | 2    |
| DragonForce–LockBit3.0 | 1      | DragonForce | 1    |
| Medusa–Play            | 1      | Medusa      | 1    |

示す。

LockBit3.0 では、延長割合が 25.1%、期限前公開が 10.9%、期限前削除が 13.0% であり、期限に基づく運用と期限前の状態変化が併存していた。Play では、延長割合が 4.4%、期限前公開が 1.2% と小さく、公開期限の表示が日付単位である点に注意は必要であるものの、対象グループの中では公開期限に比較的沿った運用が行われていた。DragonForce でも、期限延長は 14.1% であり、期限前公開は確認されなかった。Medusa では、期限前公開が 77.4% と高く、公開期限が実際の公開時刻を厳密に示すものではない可能性がある。Qilin では、延長割合が 88.2%、延長回数の平均が 25.7 回であり、公開期限を繰り返し延長しながら掲載を継続する運用が確認された。

以上より、RQ2 に対して、公開期限の運用はグループごとに大きく異なり、期限前公開、期限延長、期限前削除の発生傾向にも差異があることが分かった。

#### 4.3 共通被害者の分析

RQ3 に答えるため、複数のランサムウェアグループのリークサイトに共通して掲載された被害者を分析した。表 4 に、グループ組合せにおける共通被害者数と掲載順序を示す。

共通被害者数は件数としては確認されたものの、各グループの総被害者数に対する割合は小さい。例えば、LockBit3.0 と Play の共通被害者 10 件は、LockBit3.0 全体の 1,889 件に対して 0.53%、Play 全体の 1,025 件に対して 0.98% であった。ま

た、Play と Qilin の共通被害者 9 件は、Play 全体の 1,025 件に対して 0.88%、Qilin 全体の 1,309 件に対して 0.69% に相当する。Medusa と Qilin の共通被害者 5 件は、Medusa 全体の 272 件に対して 1.84%、Qilin 全体の 1,309 件に対して 0.38% であった。このことから、複数グループ間で共通して掲載される被害者は存在するものの、全体に占める割合は限定的であることが分かる。

掲載順序を見ると、LockBit3.0–Play および LockBit3.0–Qilin では、それぞれ 10 件すべてで Play または Qilin が後続していた。また、Play–Qilin では 9 件中 8 件、Medusa–Qilin では 5 件中 4 件で Qilin が後続しており、一部の組合せでは後続掲載グループに偏りが確認された。

以上より、RQ3 に対して、複数グループに共通して掲載される被害者は全体に対して限定的である一方、一部の組合せでは掲載順序に偏りが確認された。

## 5. 考 察

本節では、前節で示した分析結果に基づき、ランサムウェアリークサイトの運用実態、公開期限の意味、複数グループ横断分析の意義、および本研究の限界について考察する。

### 5.1 リークサイト運用のグループ差

RQ1 の結果は、リークサイトに掲載される情報項目の差異が、単なるサイト設計上の違いではなく、脅迫時に何を強調するかという運用方針の違いを反映している可能性を示している。閲覧数や漏洩情報の一部は第三者からの注目や窃取事実の信憑性を示す要素であり、公開期限は時間的圧力を与える要素である。一方で、漏洩情報のサイズや攻撃者コメントを中心に提示するグループでは、データ量や攻撃者側の主張によって圧力を与えている可能性がある。したがって、リークサイトの掲載項目は、被害者情報の単なる特性ではなく、グループごとの脅迫方針を推定するための観測対象として扱う必要がある。

また、掲載状態の推移の差異は、各グループがリークサイトをどの程度動的に管理しているかを示す手がかりとなる。再掲載や掲載終了が多いグループでは、被害者情報が交渉状況やサイト運用に応じて頻繁に操作されている可能性がある。一方、掲載状態が安定しているグループでは、一度掲載した被害者情報を継続的に公開し続ける運用が中心であると考えられる。

### 5.2 公開期限の解釈

RQ2 の結果は、リークサイト上の公開期限を一律に「実際の公開予定時刻」と解釈することの危険性を示している。Play のように期限前公開や延長が少ないグループでは、公開期限は一定程度、公開リスクを評価する手がかりとなる。一方で、Medusa のように期限前公開が多いグループでは、表示期限まで猶予があると判断することは危険である。また、Qilin のように期限延長が多いグループでは、公開期限は固定的な締切というよりも、交渉や脅迫を継続し、活動を示威するために調整される情報として解釈すべきである。したがって、被害対応や脅威分析では、公開期限そのものだけでなく、対象グループの過去の期限運用傾向を踏まえて公開リスクを評価する必要がある。

### 5.3 複数グループ横断分析の意義

RQ3 の結果から、複数グループに共通して掲載される被害者は、全体に対して限定的である一方、一部のグループ間では掲載順序に偏りが見られた。このことは、同一または類似する被害者情報が複数グループのリークサイトに現れる事例が存在することを示している。

ただし、この結果のみから、グループ間で直接的な情報共有が行われた、あるいは IAB が移動したと断定することはできない。同一組織が複数回攻撃された可能性、同一企業グループ内の関連組織が別々に掲載された可能性、あるいは被害者名の表記ゆれによって同一または類似して見える可能性もある。そのため、共通被害者の分析結果は、グループ間の関係性を直接証明するものではなく、ランサムウェアグループ間の被害者情報の再利用や攻撃対象の重複可能性を検討するための手がかりとして位置づけるべきである。

それでも、複数グループを横断して比較することには意義がある。単一グループの分析では、観測された掲載状態や公開期限の運用がそのグループ固有の特徴なのか、ランサムウェアリークサイトに共通する傾向なのかを判断しにくい。本研究では、複数グループを対象に比較することで、掲載情報、掲載状態、公開期限の運用がグループごとに異なること、および被害者の重複が全体として限定的であることを示した。したがって、ランサムウェア攻撃の運用実態を理解するためには、複数グループを継続的に観測し、横断的に比較することが重要である。

### 5.4 本研究の限界

本研究にはいくつかの限界がある。第一に、本研究の分析はリークサイト上で公開された情報に基づいており、実際の交渉内容、支払いの有無、攻撃者内部の意思決定を直接観測したものではない。そのため、掲載削除、公開期限の延長、期限前公開、再掲載といった事象の理由を断定することはできない。例えば、掲載削除は支払いによる可能性もあるが、攻撃者側の運用変更、サイト管理上の都合などによって生じた可能性もある。

第二に、観測期間や収集開始時期がグループごとに異なる。LockBit3.0 は 2023 年 6 月から観測している一方、Play、DragonForce、Medusa、Qilin はより後の時期から観測している。そのため、グループ間の件数や割合を比較する際には、観測期間の長さや活動時期の違いを考慮する必要がある。

第三に、本研究ではリークサイトを原則 6 時間ごとに観測しているが、HTML 構造や CSS クラス名の変更、アクセス制限、サイト停止などにより、一部の観測に失敗する場合がある。そのため、短時間の掲載、削除、期限変更を完全には捕捉できていない可能性がある。また、Play では公開期限が日付単位で表示されるため、期限前公開や期限後公開の判定には最大 1 日程度の曖昧さが含まれる。さらに、掲載が確認できなくなった理由が、攻撃者による削除、サイト障害、HTML 構造の変更、アクセス制限、または収集側の失敗のいずれであるかを、本研究の収集データのみから厳密に区別することはできない。

第四に、共通被害者の判定には不確実性がある。本研究で

は、被害組織名、ドメイン、説明文などに基づいて同一または類似する被害者を推定したが、企業名の表記ゆれ、同一企業グループ内の関連組織、名称が似ている別組織を完全に区別することは難しい。そのため、共通被害者の分析結果は、グループ間の直接的な関係を示す証拠ではなく、追加調査のための手がかりとして解釈する必要がある。

## 6. ま と め

本研究では、ランサムウェア攻撃者がリークサイトをどのように脅迫手段として運用しているのかを明らかにするため、LockBit3.0、Play、DragonForce、Medusa、Qilin の 5 グループを対象に、リークサイト上の被害者情報を継続的に収集し、掲載情報、掲載状態の時間的変化、公開期限の運用、ならびに複数グループに共通して掲載される被害者を分析した。

RQ1 では、共通する掲載項目が存在する一方で、グループごとに異なる項目構成も確認され、脅迫方針の違いを反映している可能性が示された。また、掲載状態の推移についても、LockBit3.0 や Medusa のように再掲載を含む変動が見られるグループ、DragonForce のように掲載数が増加し一部期間で期限付き掲載がまとまって増加するグループ、Qilin のように期限付き掲載を一定規模で維持するグループ、Play のように比較的安定して推移するグループが存在することが分かった。

RQ2 では、Play では公開期限が比較的安定して運用されていた一方、Medusa では期限前公開が多く、Qilin では期限延長や期限前削除が多いことが分かった。このことから、リークサイト上の公開期限は、必ずしも全てのグループにおいて実際の締切として機能しているわけではなく、グループごとの脅迫戦略やサイト運用方針を反映している可能性が示された。

RQ3 では、共通被害者は全体に対して限定的である一方、一部のグループ間では掲載順序に偏りが見られた。この結果は、複数グループ間で攻撃対象の重複可能性を検討する手がかりである。また、被害者の重複が全体として限定的であることから、単一グループの観測だけではランサムウェア攻撃の全体的な状況や運用実態を十分に把握できず、複数グループを横断して観測・比較する必要があることを示している。

一方で、本研究の分析はリークサイト上で公開された情報に基づくものであり、実際の交渉内容、支払いの有無、攻撃者内部の意思決定を直接観測したものではない。また、観測期間や収集開始時期はグループごとに異なり、共通被害者の判定にも表記ゆれや関連組織の混在による不確実性がある。今後は、観測対象グループと観測期間を拡張するとともに、リークサイト以外の情報源や外部インテリジェンスとの突合により、掲載状態の変化や共通被害者の意味付けをより詳細に分析する必要がある。

### 倫理的配慮

本研究では、リークサイト上で公開されているメタデータのみを収集対象とし、漏洩ファイルのダウンロードや内容確認は行っていない。結果の提示にあたっては、被害組織名を匿名化し、個別組織が特定されない形で集計結果を示した。また、観測はリークサイト上で公開されている情報の受動的な

収集に限定し、攻撃者との接触、交渉への介入、攻撃者インフラへの操作は行っていない。

**謝辞** 本研究の一部は、NEDO（国立研究開発法人新エネルギー・産業技術総合開発機構）の委託事業「経済安全保障重要技術育成プログラム／先進的サイバー防御機能・分析能力強化」（JPNP24003）によるものである。

## 文 献

- [1] T. Meurs, E. Cartwright, A. Cartwright, M. Junger, and A. Abhishta, “Deception in double extortion ransomware attacks: An analysis of profitability and credibility,” *Computers & Security*, vol. 138, 103670, 2024.
- [2] 関根悠司, Yin Minn Pa Pa, 吉岡克成, 松本勉, “LockBit3.0 ウェブサイトのデータ変遷に基づく攻撃者と被害者の行動の分析,” *信学技報*, 2024.
- [3] Y. M. Pa Pa, Y. Sekine, Y. Kawaguchi, T. Yogo, K. Lubbertsen, R. van Wegberg, M. van Eeten, and K. Yoshioka, “A longitudinal analysis of LockBit 3.0’s extortion lifecycle and response to law enforcement,” in *Proc. 28th International Symposium on Research in Attacks, Intrusions and Defenses (RAID 2025)*, pp. 538–551, 2025.
- [4] H. Oz, A. Aris, A. Levi, and A. S. Uluagac, “A survey on ransomware: Evolution, taxonomy, and defense solutions,” *ACM Computing Surveys*, vol. 54, no. 11s, article 238, pp. 1–37, 2022.
- [5] K. Oosthoek, J. Cable, and G. Smaragdakis, “A tale of two markets: Investigating the ransomware payments economy,” *Communications of the ACM*, vol. 66, no. 8, pp. 74–83, 2023.
- [6] 警察庁, “令和 7 年におけるサイバー空間をめぐる脅威の情勢等について,” [https://www.npa.go.jp/publications/statistics/cybersecurity/data/R7/R07\\_cyber\\_jousei.pdf](https://www.npa.go.jp/publications/statistics/cybersecurity/data/R7/R07_cyber_jousei.pdf).
- [7] Selenium Project, “Selenium WebDriver Documentation,” <https://www.selenium.dev/documentation/webdriver/>.
- [8] Beautiful Soup, “Beautiful Soup Documentation,” <https://www.crummy.com/software/BeautifulSoup/>.
- [9] Plotly Technologies Inc., “Plotly,” <https://plotly.com/>.
- [10] M. Bachmann, “RapidFuzz,” <https://github.com/rapidfuzz/RapidFuzz>.
- [11] dperson, “torproxy,” <https://github.com/dperson/torproxy>.
- [12] Europol, “Law enforcement disrupt world’s biggest ransomware operation,” Feb. 2024. <https://www.europol.europa.eu/media-press/newsroom/news/law-enforcement-disrupt-worlds-biggest-ransomware-operation>.
- [13] National Crime Agency, “The NCA announces the disruption of LockBit with Operation Cronos,” Feb. 2024. <https://www.nationalcrimeagency.gov.uk/the-nca-announces-the-disruption-of-lockbit-with-operation-cronos>.
- [14] ZoomInfo Technologies LLC, “ZoomInfo,” <https://www.zoominfo.com/>.